

Cloud Risk Assessment Package

Version 1.2

August 2026

Prepared By: Brandon Schuerenberg

Framework Alignment: NIST CSF 2.0 / HIPAA Security Rule

EXECUTIVE SUMMARY

System: Load Tracking Solutions (LTS) — Client name anonymized per engagement agreement

Assessment Date: August 2026

PURPOSE

This document presents the results of a security risk assessment for Load Tracking Solutions (LTS), a cloud-based asset tracking and logistics management platform. The assessment evaluates five core security controls against NIST Cybersecurity Framework 2.0 and HIPAA Security Rule requirements.

SCOPE

The assessment covers identity and access management, network boundary protection, audit logging, system monitoring, and user authentication. Five findings were identified: two High, two Medium, and one Low. All findings have documented remediation plans with target completion dates between July and August 2026.

KEY FINDINGS

- 2 High-risk findings requiring immediate remediation
- 2 Medium-risk findings with planned remediation within 90 days
- 1 Low-risk finding addressed during normal maintenance cycle

RECOMMENDATION

Load Tracking Solutions demonstrates adequate security posture for commercial and healthcare data handling, contingent on completion of open POA&M items. Continued operation is recommended with remediation in progress.

COMMERCIAL COMPLIANCE CROSSWALK

The following maps NIST SP 800-53 Rev 5 controls implemented in this assessment to NIST Cybersecurity Framework 2.0 and HIPAA Security Rule requirements for commercial and healthcare environments.

NIST 800-53 Control	NIST CSF 2.0 Function and Category	HIPAA Security Rule Citation	Business Translation
AC-3 Access Enforcement	PR.AA-01: Identities and credentials managed for authorized users	Section 164.312(a)(1): Access Control	Only authorized staff can access patient data or critical systems based on role.
SC-7 Boundary Protection	PR.DS-05 / PR.PT-04: Protections at external interfaces	Section 164.312(e)(1): Transmission Security	Network segmentation prevents breach spread across zones.
AU-2 Event Logging	DET.CM-01: Networks monitored for adverse events	Section 164.312(b): Audit Controls	All access and data interactions logged and reviewed for unauthorized activity.
SI-4 System Monitoring	DE.AE-02: Adverse events analyzed for attack methods	Section 164.308(a)(1)(ii)(D): Info System Activity Review	Continuous monitoring identifies threats before breaches or violations.
IA-2 Identification and Authentication	PR.AA-02: Users authenticated and identities verified	Section 164.312(d): Person or Entity Authentication	Unique credentials with MFA. No shared accounts. Full accountability.

SYSTEM DESCRIPTION

System Name: Load Tracking Solutions (LTS) — Anonymized

System Purpose: Provides real-time tracking and documentation of high-value assets in transit using AWS cloud services with redundant storage and automated audit trails.

Data Types Handled: Shipment manifests (business confidential), customer PII (protected health information where applicable), asset tracking data, real-time location updates, delivery confirmation records.

System Location: AWS Commercial Cloud (us-east-1)

Users: Logistics coordinators, compliance officers, program managers, and authorized external partners with approved access.

System Boundary: EC2 application servers, RDS database, S3 storage for manifests, VPC with public and private subnets, API Gateway for external partner integration, CloudTrail for audit logging.

Data Classification: Business Confidential / Protected Health Information (where applicable under HIPAA)

CONTROL STATEMENTS

Project: Load Tracking Solutions (LTS) — Anonymized

Date: August 2026

Purpose: Document the five security controls selected for this risk assessment, with statements defining what each control requires under NIST CSF 2.0 and HIPAA.

AC-3 (Access Enforcement)

NIST CSF 2.0: PR.AA-01

HIPAA: §164.312(a)(1)

The system enforces access control policies to ensure that only authorized users and processes can access sensitive resources based on assigned roles and responsibilities.

SC-7 (Boundary Protection)

NIST CSF 2.0: PR.DS-05, PR.PT-04

HIPAA: §164.312(e)(1)

Monitor ingress and egress traffic at all external interfaces. Ensure only approved endpoints are used for data transmission. Segment networks to isolate sensitive systems from public-facing components.

AU-2 (Event Logging)

NIST CSF 2.0: DET.CM-01

HIPAA: §164.312(b)

Generate audit logs for all API calls, user authentications, and data access events. Retain logs for a minimum of 90 days. Review logs on a defined schedule to detect anomalies and unauthorized activity.

SI-4 (System Monitoring)

NIST CSF 2.0: DE.AE-02

HIPAA: §164.308(a)(1)(ii)(D)

Continuously monitor system activity to detect indicators of compromise, misuse, and policy violations. Analyze detected events to understand attack methods and trigger appropriate response actions.

IA-2 (Identification & Authentication)

NIST CSF 2.0: PR.AA-02

HIPAA: §164.312(d)

All users must be uniquely identified and authenticated before accessing system resources. Multi-factor authentication is required for privileged accounts. Shared accounts are prohibited.

CONTROL SELECTION RATIONALE

Project: Load Tracking Solutions (LTS) — Anonymized

Date: August 2026

SELECTED CONTROLS

AC-3 (Access Enforcement): The system handles sensitive business data and protected health information. Restricting access to authorized personnel based on role is foundational to both NIST CSF and HIPAA compliance.

SC-7 (Boundary Protection): External partners access the system through API endpoints. This boundary must be controlled and monitored to prevent unauthorized access to internal systems and sensitive data.

AU-2 (Audit Events): Both NIST CSF 2.0 and HIPAA require audit logging for accountability and incident detection. Logs provide the forensic trail necessary for compliance audits and breach investigations.

SI-4 (System Monitoring): Continuous monitoring is required under HIPAA §164.308(a)(1)(ii)(D) and NIST CSF DE.AE. Automated detection reduces time-to-discovery for security incidents.

IA-2 (Identification & Authentication): Unique user identification and MFA enforcement are explicit requirements under HIPAA §164.312(d) and NIST CSF PR.AA-02. Shared accounts eliminate accountability and violate both frameworks.

CONTROLS NOT SELECTED

Controls such as CP-9 (backup) and PE-3 (physical access) were not selected because they are either inherited from AWS infrastructure or managed under separate organizational policies. The five controls above represent the boundaries directly managed by the LTS project team.

IMPLEMENTATION STATEMENTS

Project: Load Tracking Solutions (LTS) — Anonymized

Date: August 2026

Purpose: Document how each control is technically implemented using AWS services.

AC-3 (Access Enforcement)

AWS IAM enforces access control policies for all internal users and processes. IAM roles with least privilege permissions are assigned to EC2 instances and RDS databases. Security groups restrict network access to authorized IP ranges. API Gateway controls external access using API keys, with CloudTrail logging all access attempts for audit.

SC-7 (Boundary Protection)

API Gateway acts as the external boundary, authenticating all incoming requests before they reach the VPC. Inside the VPC, security groups control traffic to EC2 instances and RDS databases. The VPC is segmented into public and private subnets, with application servers in private subnets that have no direct internet access.

AU-2 (Event Logging)

CloudTrail monitors and logs system actions. Logs are ingested and analyzed by CloudWatch. EventBridge uses data from CloudWatch Logs and Insights to send SNS messages for specified activity. S3 buckets are used for long-term storage with a 90-day retention policy to meet audit requirements.

SI-4 (System Monitoring)

CloudTrail records all API calls. VPC Flow Logs capture network traffic data. GuardDuty analyzes both to detect indicators of compromise and misuse. CloudWatch monitors GuardDuty findings and triggers SNS alerts for security personnel when threats are detected.

IA-2 (Identification & Authentication)

IAM Identity Center centralizes authentication across multiple accounts and applications. Identity-based policies enforce least privilege for all IAM users and roles. Resource-based policies control access to S3 buckets containing audit logs. MFA is enforced for all privileged accounts via IAM policy. CloudTrail logs all authentication attempts for audit and accountability.

THREAT MODEL

Project: Load Tracking Solutions (LTS) — Anonymized

Date: August 8, 2026

Purpose: Identify plausible threat actors and attack vectors for the LTS cloud environment, and document how the five assessed controls mitigate each threat.

THREAT ACTORS

Insider Threat: Contractors, temporary personnel, or employees with legitimate access who misuse credentials or exfiltrate shipment manifests and customer PII. Motivated by financial gain or coercion. Relevant to logistics due to high contractor turnover and seasonal staffing.

External Attacker: Opportunistic or targeted actors exploiting exposed API endpoints, weak authentication, or unpatched systems to access shipment data, reroute assets, or deploy ransomware. Logistics platforms are attractive targets because disruption has immediate financial impact.

Supply Chain Compromise: Third-party vendors (ELD providers, fuel card services, maintenance platforms) whose compromised systems serve as entry points to LTS infrastructure. Relevant due to extensive vendor ecosystem in transportation and freight.

ATTACK VECTORS AND CONTROL MAPPING

Credential Theft and Account Takeover

Vector: Phishing, credential stuffing, or shared account abuse targeting logistics coordinators and contractors.

Impact: Unauthorized access to shipment manifests, customer PII, and asset tracking data. Potential HIPAA breach if PHI is exposed.

Mitigating Controls: IA-2 (unique credentials, MFA enforcement), AC-3 (role-based access enforcement).

Both controls directly prevent unauthorized access from stolen or shared credentials.

API Endpoint Exploitation

Vector: Unauthenticated or poorly authenticated API calls to external partner integrations. Injection attacks against manifest upload or tracking query endpoints.

Impact: Data exfiltration, manifest tampering, or lateral movement into internal VPC.

Mitigating Controls: SC-7 (API Gateway boundary protection, VPC segmentation), AU-2 (logging all API calls for forensic analysis). Boundary controls limit exposure; logging enables detection and response.

Lateral Movement After Initial Compromise

Vector: Attacker gains foothold through one compromised account or endpoint and moves laterally to

Vector: Sensitive data transferred out through unsanctioned endpoints, personal email, or unencrypted transfers without detection.

Impact: Breach of business-confidential shipment data or PHI. Undetected exfiltration extends dwell time and increases regulatory penalty exposure.

Mitigating Controls: AU-2 (audit logging captures all data access events), SI-4 (continuous monitoring flags anomalous transfer volumes or destinations). Detection reduces dwell time and supports breach investigation.

RISK CONTEXT FOR LOGISTICS AND HEALTHCARE

Logistics platforms handling customer PII and shipment manifests face elevated risk because:

- Shipment data reveals supply chain patterns valuable to competitors and nation-state actors
- Customer PII in transit documentation triggers HIPAA obligations when healthcare-related shipments are involved
- High contractor turnover increases insider threat surface and credential management complexity
- API-heavy architectures required for broker/carrier/shipper integration expand the external attack surface

The five controls assessed in this package address the highest-probability attack vectors for this specific operational context. Controls not selected (CP-9, PE-3) are inherited from AWS infrastructure or managed under separate organizational policies and do not represent gaps within the LTS team's direct scope of responsibility.

POA&M REMEDIATION TRACKER

POAM ID	Controls	Weakness Description	Risk Rating	Point of Contact	Resources Required	Remediation Plan	Scheduled Completion Date	Status	Status Date
POA&M-001	IA-2	Contractors and researchers lack unique credentials; shared accounts exist for temporary personnel.	Medium	Compliance Lead	Reallocation	Inventory all contractor accounts. Create unique credentials for each contractor and researcher. Disable all shared accounts.	09/15/2026	In Progress	08/08/2026
POA&M-002	AC-3	Legacy service accounts lack MFA enforcement.	High	Compliance Lead	Reallocation	Identify all legacy service accounts. Migrate accounts to IAM roles. Enforce MFA on all remaining accounts.	09/30/2026	In Progress	08/08/2026
POA&M-003	SC-7	No intrusion detection at API Gateway boundary.	Medium	Security Team	Unfunded	Evaluate IDS/IPS options for API Gateway. Select and procure solution. Deploy and test.	10/30/2026	Planned	08/08/2026
POA&M-004	SI-4	GuardDuty findings do not trigger automated alerts.	High	Compliance Lead	Reallocation	Configure CloudWatch to monitor GuardDuty. Create SNS alert thresholds. Test alerting with simulated findings.	10/15/2026	In Progress	08/08/2026
POA&M-005	AU-2	Audit logs not reviewed on a regular schedule.	Low	Compliance Lead	Funded	Define weekly log review schedule. Assign reviewer rotation. Complete first review and document results.	09/01/2026	In Progress	08/08/2026

KEY AND DEFINITIONS

RISK RATING KEY

High: Requires immediate action. Exploitation likely or significant business impact.

Medium: Requires planned action within 90 days.

Low: Address during normal maintenance cycle.

STATUS KEY

Planned: Remediation scheduled but not yet started.

In Progress: Active work underway.

Completed: Remediation verified and closed.

RESOURCES KEY

Funded: Budget already allocated.

Unfunded: Budget needs to be requested.

Reallocation: Existing budget being redirected.

COLUMN DEFINITIONS

POAM ID: Unique identifier for tracking.

Controls: Security control reference (NIST 800-53 / NIST CSF 2.0 / HIPAA).

Weakness Description: Specific deficiency or gap identified.

Risk Rating: Prioritization level (High / Medium / Low).

Point of Contact: Person or role responsible for remediation.

Resources Required: Funding status (Funded / Unfunded / Reallocation).

Remediation Plan: Specific steps to resolve the weakness.

Scheduled Completion Date: Target date for remediation.

Status: Current progress (Planned / In Progress / Completed).

Status Date: Date status was last updated.